

TokTickIT — API Specification (Lab 3)

1. Conventions

- **Base URL:** `/api`
- **Content-Type:** `application/json` for all requests/responses.
- **Timestamps:** ISO 8601 UTC strings, server-generated.
- **Authentication:** all endpoints except `POST /api/auth/login` require a valid authenticated session. Unauthenticated requests return `401`.
- **Session:** successful login issues a signed JWT in the `tt_session` HTTP-only cookie. The cookie uses `SameSite=Strict`, `Path=/`, `Max-Age=28800` (8 hours), and `Secure` outside local environments.
- **CSRF:** all `POST / PATCH / DELETE` requests require `X-Requested-With: TokTickIT`; missing header returns `403`.
- **IDs:** opaque strings (UUIDs). `ticketNumber` is the human-facing identifier and is not used as the resource `id` lookup key unless explicitly stated.
- **Enums:** enum values use `UPPER_SNAKE_CASE` on the wire.
- **Errors:** a consistent envelope is used for all non-2xx responses:

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Human-readable, non-sensitive message."
  }
}
```

- **Security:** responses never expose passwords, password hashes, stack traces, SQL fragments, internal file paths, or protected data belonging to another user.

2. Authentication & Session Endpoints

`POST /api/auth/login`

Authenticates a user with email and password.

- **Auth:** none
- **Request body:**

```
{  
  "email": "janderson@tiktockit.com",  
  "password": "string"  
}
```

- **Response 200:**

```
{  
  "user": {  
    "id": "usr_123",  
    "name": "Jennifer Anderson",  
    "email": "janderson@tiktockit.com",  
    "role": "REQUESTER",  
    "mustChangePassword": false  
  }  
}
```

Also sets the `tt_session` cookie.

- **Response 400:** missing or malformed email/password.
- **Response 401:** unknown email or incorrect password:

```
{  
  "error": {  
    "code": "INVALID_CREDENTIALS",  
    "message": "Invalid email or password."  
  }  
}
```

- **Response 403:** correct credentials but inactive account:

```
{  
  "error": {  
    "code": "ACCOUNT_INACTIVE",  
    "message": "This account is inactive. Contact an administrator."  
  }  
}
```

POST /api/auth/logout

Logs out the current session and clears the session cookie.

- **Auth:** valid session, but no-session requests are also handled idempotently.
- **Response 204:** successful logout or no active session.
- **Behavior:** token `jti` is added to a short-lived in-memory denylist until natural expiry.

GET /api/auth/me

Returns the identity associated with the current session.

- **Auth:** valid session
- **Response 200:**

```
{
  "id": "usr_123",
  "name": "Jennifer Anderson",
  "email": "janderson@tiktockit.com",
  "role": "REQUESTER",
  "isActive": true,
  "mustChangePassword": false
}
```

- **Response 401:** no valid session.

POST /api/auth/change-password

Changes the current user's password. Used for both mandatory first-login changes and later voluntary changes.

- **Auth:** valid session
- **Request body:**

```
{
  "currentPassword": "string",
  "newPassword": "string"
}
```

- **Validation:** new password must be at least 8 characters and contain uppercase, lowercase, a number, and a special character. It must not equal the current password.
- **Response 200:**

```
{ "mustChangePassword": false }
```

- **Response 400:** password fails policy or equals current password.
- **Response 401:** no session or current password is incorrect.

3. Requester Ticket Endpoints

All Requester ownership is derived from the authenticated session. A `requesterId` supplied by the client is never trusted for ownership.

GET `/api/tickets`

Lists the authenticated Requester's own Tickets.

- **Auth:** `REQUESTER` , `IT_STAFF` , or `ADMINISTRATOR` for authenticated access to the Requester's own resource scope.
- **Query parameters:**

Param	Type	Notes
status	enum	Status filter
category	id	Category filter
sort	string	<code>createdAt</code> <code>updatedAt</code>
sortDir	string	<code>asc</code> <code>desc</code> , default <code>desc</code>

- **Response 200:**

```
{
  "items": [
    {
      "id": "tk1_1",
      "ticketNumber": "TKT-2025-000234",
      "summary": "Laptop battery drains quickly",
      "category": "Hardware",
      "requestedPriority": "MEDIUM",
      "itPriority": "MEDIUM",
      "status": "NEW",
      "createdAt": "2026-08-22T09:14:00Z",
      "updatedAt": "2026-08-22T09:14:00Z"
    }
  ]
}
```

- **Pagination:** not required for the Requester's own list in Lab 3.

POST /api/tickets

Creates a Ticket owned by the authenticated Requester.

- **Auth:** authenticated Requester
- **Request body:**

```
{
  "categoryId": "cat_01",
  "relatedSystemId": "sys_04",
  "summary": "Laptop battery drains quickly",
  "description": "Battery drains fast even when idle, started after last update.",
  "requestedPriority": "MEDIUM"
}
```

- **Validation:** required summary, valid Category, valid Related System, and valid requested priority. Other Lab 2 ticket validation rules continue to apply unless changed by Lab 3.
- **Server-generated fields:**
 - requesterId = authenticated session user
 - itPriority = requestedPriority
 - status = NEW
 - ticketOwnerId = null
 - problemAppearsResolved = false

- **Response 201:** full Ticket object.
- **Response 400:** validation failure.

GET /api/tickets/:id

Retrieves one Ticket owned by the authenticated Requester.

- **Auth:** authenticated Requester; ownership is checked server-side.
- **Response 200:** full Ticket object using the Requester projection; Internal Notes are not included.
- **Response 403:** Ticket exists but belongs to another Requester. No Ticket data is returned.
- **Response 404:** Ticket does not exist.

GET /api/tickets/:id/comments

Lists Public Comments for a Ticket.

- **Auth:** Requester may access comments on their own Ticket; IT Staff/Administrator may access comments on any Ticket.
- **Response 200:**

```
{
  "items": [
    {
      "id": "cmt_1",
      "ticketId": "tk1_1",
      "authorId": "usr_123",
      "authorName": "Jennifer Anderson",
      "authorRole": "REQUESTER",
      "content": "The issue is still happening.",
      "createdAt": "2026-08-22T10:00:00Z"
    }
  ]
}
```

- **Response 403:** Requester does not own the Ticket.

POST /api/tickets/:id/comments

Adds a Public Comment to a Ticket.

- **Auth:** Requester on their own Ticket; IT Staff/Administrator on any Ticket.

- **Request body:**

```
{  
  "content": "The issue is still happening."  
}
```

- **Validation:** content must be 1–2000 characters and cannot be empty or whitespace-only.

- **Response 201:**

```
{  
  "id": "cmt_1",  
  "ticketId": "tk1_1",  
  "authorId": "usr_123",  
  "authorName": "Jennifer Anderson",  
  "authorRole": "REQUESTER",  
  "content": "The issue is still happening.",  
  "createdAt": "2026-08-22T10:00:00Z"  
}
```

- **Response 400:** invalid content.
- **Response 403:** Requester does not own the Ticket.

PATCH /api/tickets/:id/resolution

Marks whether the problem appears resolved.

- **Auth:** authenticated Requester who owns the Ticket.
- **Request body:**

```
{  
  "problemAppearsResolved": true  
}
```

- **Response 200:** updated Ticket .
- **Response 403:** caller is not the Ticket's Requester.
- **Response 409:** Ticket status is not OPEN , IN_PROGRESS , OR WAITING_FOR_REQUESTER .

4. Attachment Endpoints

Attachment endpoints retain the Lab 2 shape, but ownership is derived from the authenticated session instead of `X-Dev-Requester-Id`. The old development requester header is no longer read.

GET `/api/tickets/:id/attachments`

Lists Attachment metadata for an owned Ticket.

- **Auth:** authenticated owner; Staff/Administrator access follows the ticket authorization rules.
- **Response 200:**

```
{
  "data": [
    {
      "attachmentId": "att_101",
      "originalFileName": "screenshot.png",
      "status": "ACTIVE",
      "uploadedAt": "2026-08-22T09:15:00Z"
    },
    {
      "attachmentId": "att_99",
      "originalFileName": "old-log.pdf",
      "status": "REMOVED",
      "uploadedAt": "2026-08-20T10:00:00Z",
      "removedAt": "2026-08-21T08:00:00Z",
      "removalReason": "Duplicate of screenshot.png"
    }
  ]
}
```

POST `/api/tickets/:id/attachments`

Uploads an Attachment to an owned Ticket.

- **Auth:** authenticated owner; ownership uses the session identity.
- **Request:** `multipart/form-data`, field `file`.
- **Validation:**

Rule	Requirement
File type	.jpg / .jpeg / .png / .webp / .pdf , checked by extension and MIME
Maximum size	5 MB
Active attachment limit	Fewer than 5 active Attachments

- **Response 201:**

```
{
  "data": {
    "attachmentId": "att_102",
    "originalFileName": "invoice.pdf",
    "status": "ACTIVE",
    "uploadedAt": "2026-08-22T09:20:00Z"
  }
}
```

- **Response 404:** Ticket not found / not owned.
- **Response 413:** file exceeds 5 MB.
- **Response 415:** file type is not allowed.
- **Response 422:** upload would exceed the 5 active-Attachment limit.

GET /api/attachments/:id/download

Downloads an active Attachment.

- **Auth:** authenticated user with access to the Attachment's Ticket.
- **Response 200:** binary file stream with
Content-Disposition: attachment; filename="<originalFileName>" .
- **Response 404:** Attachment not found, inaccessible, or REMOVED .

DELETE /api/attachments/:id

Removes an Attachment.

- **Auth:** authenticated user with ownership/access to the Attachment's Ticket.
- **Behavior:** soft-removes the Attachment rather than physically deleting it.
- **Response:** follows the Lab 2 removal semantics; the Attachment becomes REMOVED .

5. IT Staff Endpoints

All endpoints in this section require role `IT_STAFF` or `ADMINISTRATOR` .

GET `/api/staff/tickets`

Lists the IT Staff Ticket Queue.

- **Auth:** `IT_STAFF` or `ADMINISTRATOR`
- **Query parameters:**

Param	Type	Notes
q	string	Matches Ticket Number or Summary, case-insensitive substring
status	enum	One status
category	id	Category filter
requestedPriority	enum	Requested priority filter
itPriority	enum	IT priority filter
owner	string	me unassigned user id
sort	string	createdAt updatedAt itPriority status , default createdAt
sortDir	string	asc desc , default desc
page	integer	≥ 1, default 1
pageSize	integer	1–50, default 10

- **Response 200:**

```

{
  "items": [
    {
      "id": "tk1_1",
      "ticketNumber": "TKT-2025-000234",
      "summary": "Laptop battery drains quickly",
      "category": "Hardware",
      "requestedPriority": "MEDIUM",
      "itPriority": "MEDIUM",
      "status": "IN_PROGRESS",
      "owner": {
        "id": "usr_9",
        "name": "Michael Brown"
      },
      "createdAt": "2026-08-22T09:14:00Z",
      "updatedAt": "2026-08-22T09:30:00Z"
    }
  ],
  "page": 1,
  "pageSize": 10,
  "totalItems": 87,
  "totalPages": 9
}

```

- **Response 400:** invalid query parameter; response identifies the offending parameter and does not silently apply the invalid filter.
- **Empty result:** 200 with "items": [] ; this is a valid no-results state.
- **Response 403:** caller is a Requester.

GET /api/staff/tickets/:id

Retrieves full Ticket detail for IT Staff.

- **Auth:** IT_STAFF OR ADMINISTRATOR
- **Response 200:** Ticket object including owner , itPriority , internalNotesCount , and existing Attachments.
- **Response 404:** Ticket not found.

PATCH /api/staff/tickets/:id/owner

Claims, assigns, reassigns, or unassigns Ticket ownership.

- **Auth:** IT_STAFF or ADMINISTRATOR
- **Request body:**

```
{
  "ownerId": "usr_9"
}
```

Use "ownerId": null to unassign.

- **Response 200:** updated Ticket .
- **Response 400:** ownerId does not reference an existing user.
- **Response 409:** target user is not an active IT Staff or Administrator.

PATCH /api/staff/tickets/:id/priority

Changes the internal IT priority.

- **Auth:** IT_STAFF or ADMINISTRATOR
- **Request body:**

```
{
  "itPriority": "HIGH"
}
```

- **Response 200:** updated Ticket .
- **Response 400:** invalid priority enum.
- **Rule:** requestedPriority is never changed by this endpoint.

PATCH /api/staff/tickets/:id/status

Changes the Ticket status.

- **Auth:** IT_STAFF or ADMINISTRATOR
- **Request body:**

```
{
  "status": "RESOLVED",
  "resolutionSummary": "Optional resolution description."
}
```

- **Response 200:** updated Ticket .
- **Response 409:** requested status transition is not allowed. The response includes the current status and statuses that are legally reachable from it.

GET /api/staff/tickets/:id/notes

Lists Internal Notes for a Ticket.

- **Auth:** IT_STAFF OR ADMINISTRATOR
- **Response 200:** Internal Note objects.
- **Response 403:** Requester; no note content is disclosed.

POST /api/staff/tickets/:id/notes

Creates an Internal Note.

- **Auth:** IT_STAFF OR ADMINISTRATOR
- **Request body:**

```
{  
  "content": "Contacted the requester and requested additional logs."  
}
```

- **Validation:** content must be 1–2000 characters and cannot be empty.
- **Response 201:**

```
{  
  "id": "note_1",  
  "ticketId": "tk1_1",  
  "authorId": "usr_9",  
  "authorName": "Michael Brown",  
  "content": "Contacted the requester and requested additional logs.",  
  "createdAt": "2026-08-22T10:00:00Z"  
}
```

- **Response 400:** invalid content.
- **Response 403:** caller is a Requester.

GET /api/staff/tickets/:id/comments

Lists Public Comments using the staff-prefixed route.

- **Auth:** IT_STAFF OR ADMINISTRATOR
- **Response 200:** same Public Comment shape as §3.

POST /api/staff/tickets/:id/comments

Creates a Public Comment using the staff-prefixed route.

- **Auth:** IT_STAFF OR ADMINISTRATOR
- **Request body:**

```
{  
  "content": "We are investigating the issue."  
}
```

- **Validation:** same 1–2000 character Public Comment rules as §3.
- **Response 201:** same Public Comment shape as §3.
- **Response 400:** invalid content.

6. Administrator Endpoints

All endpoints in this section require role ADMINISTRATOR .

GET /api/admin/users

Lists users for User Management.

- **Auth:** ADMINISTRATOR
- **Query parameters:**

Param	Type	Notes
q	string	Matches name or email, case-insensitive substring
role	enum	Optional exact role filter

- **Pagination:** not required in Lab 3.
- **Response 200:**

```
{
  "items": [
    {
      "id": "usr_1",
      "name": "Jennifer Anderson",
      "email": "janderson@tiktockit.com",
      "role": "IT_STAFF",
      "isActive": true
    }
  ]
}
```

- **Response 403:** caller is not an Administrator.

POST /api/admin/users

Creates a new user.

- **Auth:** ADMINISTRATOR
- **Request body:**

```
{
  "name": "Alex Thompson",
  "email": "alex.thompson@tiktockit.com",
  "role": "IT_STAFF",
  "isActive": true,
  "initialPassword": "string"
}
```

- **Validation:** required/valid fields and password policy.
- **Response 201:** created User ; never includes passwordHash .
mustChangePassword is forced to true .
- **Response 400:** invalid fields or password policy failure.
- **Response 409:** duplicate email:

```
{
  "error": {
    "code": "DUPLICATE_EMAIL",
    "message": "A user with this email already exists."
  }
}
```

GET /api/admin/users/:id

Retrieves one User for edit-panel prefill.

- **Auth:** ADMINISTRATOR
- **Response 200:** single User .
- **Response 404:** User not found.

PATCH /api/admin/users/:id

Edits a user's name, email, role, and/or activation state.

- **Auth:** ADMINISTRATOR
- **Request body:** any subset of:

```
{
  "name": "string",
  "email": "string",
  "role": "REQUESTER",
  "isActive": true
}
```

- **Response 200:** updated User .
- **Response 400:** invalid role or malformed email.
- **Response 409:** duplicate email, last active Administrator protection, or self-deactivation.
- **Example errors:**

```
{
  "error": {
    "code": "LAST_ADMIN",
    "message": "At least one active administrator is required."
  }
}
```

```
{
  "error": {
    "code": "SELF_DEACTIVATION",
    "message": "You cannot deactivate your own account."
  }
}
```

PATCH /api/admin/users/:id/password

Sets a new initial password.

- **Auth:** ADMINISTRATOR
- **Request body:**

```
{  
  "newPassword": "string"  
}
```

- **Response 200:**

```
{  
  "mustChangePassword": true  
}
```

- **Response 400:** password fails policy.
- **Response 404:** User not found.

7. Reference Data Endpoints

Lab 2 reference-data endpoints continue into Lab 3 but now require an authenticated session. Their response shapes remain unchanged unless otherwise specified.

GET /api/categories

Lists active Categories.

- **Auth:** valid session
- **Response 200:**

```
{  
  "data": [  
    { "id": "cat_01", "name": "Hardware" },  
    { "id": "cat_02", "name": "Software" }  
  ]  
}
```

GET /api/related-systems

Lists active Related Systems.

- **Auth:** valid session
- **Response 200:**

```
{
  "data": [
    { "id": "sys_01", "name": "Email" },
    { "id": "sys_04", "name": "VPN" }
  ]
}
```

GET /api/priorities

Lists available Priorities.

- **Auth:** valid session
- **Response 200:**

```
{
  "data": [
    { "id": "pri_01", "name": "Low", "sortOrder": 1 },
    { "id": "pri_02", "name": "Medium", "sortOrder": 2 },
    { "id": "pri_03", "name": "High", "sortOrder": 3 }
  ]
}
```

GET /api/statuses

Lists Ticket Statuses.

- **Auth:** valid session
- **Response 200:**

```

{
  "data": [
    { "id": "st_01", "name": "New", "isDefault": true },
    { "id": "st_02", "name": "Open", "isDefault": false },
    { "id": "st_03", "name": "In Progress", "isDefault": false },
    { "id": "st_04", "name": "Pending", "isDefault": false }
  ]
}

```

8. Authorization Matrix

Endpoint / Resource	Requester	IT Staff	Administrator
POST /api/auth/login	✓	✓	✓
POST /api/auth/logout	✓	✓	✓
GET /api/auth/me	✓	✓	✓
POST /api/auth/change-password	✓	✓	✓
GET/POST /api/tickets (own scope)	✓		
GET /api/tickets/:id (own)	✓		
GET/POST /api/tickets/:id/comments (own)	✓		
PATCH /api/tickets/:id/resolution (own)	✓		
Ticket attachment endpoints (own)	✓		
GET/POST /api/staff/tickets*	✗	✓	✓
Staff owner/priority/status updates	✗	✓	✓
Staff Internal Notes	✗	✓	✓
Staff Public Comments	✗	✓	✓
GET/POST/PATCH /api/admin/users*	✗	✗	✓
Reference data endpoints	✓	✓	✓

- A missing/invalid session returns 401 .
- An authenticated caller without permission returns 403 .
- Ownership is always re-checked server-side.
- A protected resource must not disclose another user's protected data.

9. Status Code Reference

Status	Used For
200	Successful retrieval or update
201	Ticket, Comment, Internal Note, or User created; Attachment uploaded
204	Successful logout
400	Validation failure or invalid query parameter
401	No, invalid, or expired authentication session
403	Authenticated but not authorized, including missing CSRF header
404	Resource not found or inaccessible resource
409	Current-state conflict, duplicate email, invalid status transition, assignment conflict
413	Attachment exceeds 5 MB
415	Attachment type is not allowed
422	Upload would exceed the 5 active-Attachment limit
500	Unexpected server error; generic safe message only

10. Safe Error Contract

Every non-2xx response uses:

```
{  
  "error": {  
    "code": "MACHINE_READABLE_CODE",  
    "message": "Human-readable, non-sensitive message."  
  }  
}
```

- No stack traces are returned.
- No SQL fragments or internal file paths are returned.
- No password hashes or password values are returned.
- No protected Ticket, Comment, or Internal Note content belonging to another user is returned.
- Error responses must remain safe even when the request targets a resource the caller cannot access.